كيف درّبنا نموذج اكتشاف تسرّب البيانات

دليل مبسّط لفهم الفكرة كاملة · اكتشاف تسرّب البيانات في التخزين السحابي

1. الفكرة في فقرة واحدة

تحفظ الشركات ملفاتها السرية في السحابة. وأحياناً يُخرج أحدهم البيانات دون إذن: موظف غير أمين، أو مهاجم يستخدم كلمة مرور مسروقة، أو خطأ غير مقصود. نريد أن يتمكن الحاسوب من **النظر إلى كل عملية والحكم إن كانت تبدو تسرّباً**.
ولتحقيق ذلك نعرض عليه آلاف العمليات السابقة المصنّفة مسبقاً على أنها «طبيعية» أو «تسرّب»، فيتعلّم أنماطها، وهذا ما يسمى **التدريب**. ثم نتحقق منه على عمليات لم يرها من قبل، وهذا ما يسمى **الاختبار**.

تخيّل طالباً. التدريب هو المذاكرة مع ورقة الإجابات، والاختبار هو الامتحان النهائي بأسئلة جديدة. فإذا قيّمنا الطالب على أسئلة تدرّب عليها مسبقاً، فلن تعني الدرجة شيئاً. لهذا نُبقي جزءاً من البيانات مخفياً حتى النهاية.

2. البيانات

استخدمنا مجموعة بيانات Kaggle نفسها التي استخدمتها الورقة المرجعية (Harahap & Hasibuan, 2025): **49,500 حدث في التخزين السحابي**. كل حدث هو عملية واحدة لمستخدم واحد، ومعها تصنيف: **طبيعي (68.9%)** أو **تسرّب (31.1%)**. وتحققنا من أن الملف يطابق جداول الورقة صفاً بصف.

ما ينظر إليه النموذج	أمثلة
من هو المستخدم	الدور الوظيفي: موظف، مدير، مدير أول، متدرّب، فني رئيسي
كيف سجّل الدخول	كلمة المرور، الرمز PIN، المصادقة متعددة العوامل MFA (نعم/لا)
ماذا فعل	قراءة، كتابة، نقل، حذف؛ تعديل بيانات؛ الوصول إلى بيانات سرية أو نقلها
مدى حساسية البيانات	منخفضة، متوسطة، عالية
أضفناها نحن: إلى أين ومتى	وجهة داخلية أو خارجية؛ ساعة اليوم

استخدمت الورقة السمات التسع الأولى فقط. وأضفنا السمتين الأخيرتين لأنهما موجودتان في البيانات ولهما أثر واضح: يحدث التسرّب في نحو 40% من الحالات ليلاً مقابل 16% في ساعات العمل، ويزداد عندما تذهب البيانات إلى وجهة خارجية.

3. عملية التدريب خطوة بخطوة

1

الحصول على البيانات

49,500 حدث مصنّف من Kaggle، تحققنا من مطابقتها لجداول الورقة.

2

التجهيز

استخراج الساعة من التاريخ، وحذف أعمدة التعريف، والإبقاء على 11 سمة.

3

التقسيم مرة واحدة

80% للتدريب، و20% تُحجز جانباً للامتحان النهائي.

4

التنظيف من الداخل

ملء القيم المفقودة وتحويل النصوص إلى أرقام، بالتعلّم من بيانات التدريب فقط.

5 **الضبط**
تجربة 80 إعداداً للشجرة بالتحقق المتقاطع بخمسة أجزاء، والإبقاء على الأفضل.

6 **المقارنة**
اختبار سمات ونماذج وطرق توازن أخرى.

7 **ضبط الإنذار**
اختيار درجة الخطر التي يُطلق الحدث فوقها إنذاراً.

8 **الاختبار النهائي**
تقييم الـ20% المحجوزة مرة واحدة، ثم شرح القواعد.

يجري كل ذلك في دفتر واحد على Google Colab، باستخدام لغة Python ومكتبة scikit-learn.

4. الأفكار الأساسية بشرح مبسّط

شجرة القرار (Decision Tree). يطرح النموذج أسئلة إجابتها نعم أو لا، مثل مخطط انسيابي: «هل نُقلت بيانات سرية؟ هل أُرسلت إلى الخارج؟ هل كان ذلك ليلاً؟» وفي النهاية يعطي درجة خطر. اخترناها لأن محلل الأمن يستطيع أن يقرأ سبب إطلاق الإنذار.

تقسيم التدريب والاختبار. 80% من الأحداث (39,600) للتعلّم، و20% (9,900) تُحجز وتُستخدم مرة واحدة فقط في النهاية. ولا يُتخذ أي قرار بالاعتماد عليها.

التحقق المتقاطع (Cross-validation). لمقارنة الإعدادات بإنصاف دون لمس بيانات الاختبار، نقسم بيانات التدريب إلى 5 أجزاء: ندرّب على 4 ونفحص على الخامس، ونكرر ذلك 5 مرات. والمتوسط هو الدرجة.

الضبط (Tuning). للشجرة إعدادات، مثل عدد الأسئلة المتتالية المسموح بها. جرّب الحاسوب 80 تركيبة واحتفظ بالتي حصلت على أفضل درجة في التحقق المتقاطع.

أوزان الفئات (Class weights). التسرّب هو الأقلية (31%)، لذا قد يكتفي نموذج «كسول» بقول «طبيعي» دائماً. جعلنا كل تسرّب فائت يُحسب أكثر بنحو 2.2 مرة أثناء التدريب، حتى ينتبه النموذج إلى حالات التسرّب.

عتبة الإنذار (Threshold). تعطي الشجرة كل حدث درجة خطر بين 0 و1. اخترنا الحد الفاصل (0.416) الذي يكتشف 80% على الأقل من حالات التسرّب بأقل عدد ممكن من الإنذارات الكاذبة، باستخدام بيانات التدريب فقط.

بلا غش (منع تسرّب البيانات في المنهجية). ملء القيم المفقودة وتحويل النصوص إلى أرقام يتعلّمان من بيانات التدريب فقط. وإلا تسللت معلومات من الامتحان إلى المذاكرة فتضخّمت الدرجة.

الحد الأعلى. 91% من الأحداث تبدو مطابقة لأحداث تحمل التصنيف المعاكس، ولا يستطيع أي نموذج التمييز بينها. لذلك لا يمكن تجاوز دقة 74.3% بسمات الورقة التسع. فالبيانات الأفضل أهم من النموذج الأعقد.

5. كيف نقيس النجاح

تخيّل 100 حدث: 69 طبيعية و31 تسرّباً.

المقياس	السؤال الذي يجيب عنه
الدقة (Accuracy)	كم إجابة كانت صحيحة إجمالاً؟ مضلّلة هنا: قول «طبيعي» دائماً يعطي 69% دون اكتشاف أي تسرّب.
الاستدعاء (Recall)	من بين كل حالات التسرّب الحقيقية، كم حالة اكتشفنا؟
الضبط (Precision)	من بين كل الإنذارات، كم منها كان تسرّباً حقيقياً؟
F1	درجة واحدة لا ترتفع إلا إذا كان الاستدعاء والضبط جيدين معاً.
PR-AUC	مدى قدرة النموذج على ترتيب الأحداث الخطرة قبل الطبيعية، أياً كانت العتبة.

6. ما توصّلنا إليه

أثناء العمل (تحقق متقاطع على بيانات التدريب): أدّت إضافة السمتين الجديدتين إلى تحسين النموذج أكثر بكثير (تحسّن PR-AUC بمقدار 0.12) من الانتقال إلى خوارزميات أقوى مثل Random Forest وXGBoost (تحسّن بمقدار 0.01 فقط). كما أن إعطاء التسرّب وزناً إضافياً نجح أكثر من توليد حالات تسرّب اصطناعية (SMOTEN).

الامتحان النهائي (9,900 حدث محجوز، قُيّمت مرة واحدة):

	الدقة	التسرّب المكتشف (الاستدعاء)	الضبط	F1
قول «طبيعي» دائماً	68.9%	0%	–	0.00
نموذج الورقة (بعد إعادة الفحص)	69.5%	10%	55.0%	0.17
نموذجنا النهائي	**69.6%**	**83%**	**50.7%**	**0.63**

للنموذجين الدقة نفسها تقريباً، لكن نموذجنا يكتشف **نحو 8 أضعاف حالات التسرّب**. والثمن: نحو نصف الأحداث تُطلق إنذاراً، ونحو إنذار من كل اثنين هو تسرّب حقيقي. وأقوى علامة تحذير تعلّمها النموذج هي **نقل ملف سري إلى وجهة خارجية**، خصوصاً ليلاً.

> **الفكرة كلها في جملة واحدة:** علّمنا شجرة قرار أن تتعرّف على التسرّب من 39,600 حدث مصنّف، واتخذنا كل قراراتنا باستخدام بيانات التدريب هذه فقط، ثم أثبتنا على 9,900 حدث مخفي أنها تكتشف حالات تسرّب أكثر بكثير من نموذج الورقة.

7. حدود يجب مراعاتها

السمات بسيطة وكثير من الأحداث متشابهة، لذلك يبقى الضبط عند نحو 50% مع الاستدعاء المرتفع. كما أن طريقة تصنيف البيانات غير موثّقة، وقد تكون البيانات اصطناعية، فقد لا تنطبق النتائج على سجلات سحابية حقيقية. والاستخدام الفعلي يحتاج إلى معلومات سلوكية أغنى، مثل العادات المعتادة لكل مستخدم.